

Trialbank
Independent Trial Paper A

2026

Higher School Certificate

Year 12 Trial HSC Examination

Software Engineering

General Instructions

- Reading time – 10 minutes
- Working time – 2 hours 20 minutes
- The HSC exam is completed online; answer on screen in Trialbank, or in the spaces provided on this paper
- Python is used for code questions
- Write your name at the top of every page

Total Marks: 80

Section I
Total marks (20)

- Attempt Questions 1–16
- Allow about 25 minutes for this section

Section II
Total marks (60)

- Attempt ALL questions
- Allow about 1 hour and 55 minutes for this section

STUDENT NAME: _____

Section I

20 marks

Attempt Questions 1–16

Allow about 25 minutes for this section

Questions 1–8: select ONE answer. Questions 9–12: select ALL correct answers (all must be correct for the mark). Questions 13–16: match each item to ONE option; options may be used more than once.

1 **Which line of Python safely queries the database using the variable *name*?**

◯ **A.**
```
cursor.execute("SELECT * FROM users WHERE name = '" + name + "'")
```

◯ **B.**
```
cursor.execute(f"SELECT * FROM users WHERE name = '{name}'")
```

◯ **C.**
```
cursor.execute("SELECT * FROM users WHERE name = ?", (name,))
```

◯ **D.**
```
cursor.execute("SELECT * FROM users WHERE name = %s" % name)
```

2 **A browser requests a page that does not exist on the server. Which HTTP status code is returned?**

◯ **A.** 200

◯ **B.** 301

◯ **C.** 404

◯ **D.** 500

3 **Which statement best describes a progressive web app (PWA)?**

◯ **A.** It can only be installed from an app store

◯ **B.** It runs in a browser but can be installed and work offline using a service worker

◯ **C.** It must be rewritten in native code for each operating system

◯ **D.** It is rendered entirely on the server with no client-side code

4 **A company trains a model on ten years of its past hiring decisions. The model now ranks male applicants higher. What is the most likely cause?**

◯ **A.** Overfitting caused by training for too many epochs

◯ **B.** Bias in the training data

◯ **C.** Underfitting caused by too few features

◯ **D.** A learning rate that is too small

5 **Which OOP concept is best demonstrated by this code?**

```
class Account:
    def __init__(self, balance):
        self.__balance = balance

    def deposit(self, amount):
        if amount > 0:
            self.__balance += amount
```

- ◯ **A.** Inheritance
- ◯ **B.** Polymorphism
- ◯ **C.** Encapsulation
- ◯ **D.** Generalisation

6 **A tester sends thousands of unusual HTTP requests to a running web app to see how it responds. Which method is this?**

- ◯ **A.** Static application security testing (SAST)
- ◯ **B.** Dynamic application security testing (DAST)
- ◯ **C.** Code review
- ◯ **D.** Desk checking

7 **What is the output of this code?**

```
data = [3, 8, 1, 9, 4]
result = [x * 2 for x in data if x > 3]
print(result)
```

- ◯ **A.** [6, 16, 2, 18, 8]
- ◯ **B.** [16, 18, 8]
- ◯ **C.** [8, 9, 4]
- ◯ **D.** [16, 18]

8 **A web page loads slowly because it downloads a 6 MB photo that is displayed 300 pixels wide. What is the best fix?**

- ◯ **A.** Minify the JavaScript files
- ◯ **B.** Resize and compress the image, and serve it in a modern format such as WebP
- ◯ **C.** Add more CSS rules
- ◯ **D.** Serve the page over HTTP instead of HTTPS

9 **Which of the following does HTTPS provide that HTTP does not? Select ALL that apply.**

- ☐ **A.** Data is encrypted in transit
- ☐ **B.** The server's identity is verified using a certificate
- ☐ **C.** SQL injection is prevented
- ☐ **D.** Tampering with data in transit is detected
- ☐ **E.** Pages can load without a server
- ☐ **F.** The domain name is hidden from DNS servers

10 **Select ALL statements that are true for this code.**

```
class Shape:
    def area(self):
        return 0

class Square(Shape):
    def __init__(self, side):
        self.side = side
    def area(self):
        return self.side ** 2

class Circle(Shape):
    def __init__(self, radius):
        self.radius = radius

for s in [Square(3), Circle(2)]:
    print(s.area())
```

- ☐ **A.** Square is a subclass of Shape
- ☐ **B.** Square overrides the area() method
- ☐ **C.** The output is 9 then 12.57
- ☐ **D.** The output is 9 then 0
- ☐ **E.** Circle inherits area() from its superclass
- ☐ **F.** Shape is a subclass of Circle
- ☐ **G.** The loop demonstrates polymorphism

11 **Which of these are supervised learning tasks? Select ALL that apply.**

- ☐ **A.** Predicting a house's price from its size, using past sales
- ☐ **B.** Grouping news articles by topic when none are labelled
- ☐ **C.** Classifying emails as spam using emails already labelled spam or not spam
- ☐ **D.** A robot learning to walk by receiving rewards
- ☐ **E.** Predicting whether a scan is benign using scans labelled by doctors

12 **Which measures reduce the risk or impact of cross-site scripting (XSS)? Select ALL that apply.**

- ☐ **A.** Encoding (escaping) user input before displaying it on a page
- ☐ **B.** Sending a Content Security Policy header
- ☐ **C.** Hashing passwords with bcrypt
- ☐ **D.** Validating and sanitising input
- ☐ **E.** Serving the site over HTTP instead of HTTPS
- ☐ **F.** Setting the HttpOnly flag on session cookies

13 **Match each vulnerability to its description.** **2 marks**

Item	Answer	Options
1. SQL injection		A. An attacker's script runs in another user's browser
2. Cross-site scripting (XSS)		B. A logged-in user's browser is tricked into sending an unwanted request
3. Cross-site request forgery (CSRF)		C. User input changes the meaning of a database query
4. Broken authentication		D. Weak passwords or session handling let an attacker take over an account

14 **Match each machine learning model to the task it suits best.** **2 marks**

Item	Answer	Options
1. Linear regression		A. Grouping customers who have no labels
2. Logistic regression		B. Recognising handwritten digits from pixel values
3. Decision tree		C. Predicting a house price in dollars
4. K-means clustering		D. Predicting the probability that a student passes or fails
5. Neural network		E. Making a loan decision that must be explained as a set of if-then rules

15 **Match each HTTP method to its usual purpose.** **2 marks**

Item	Answer	Options
1. GET		A. Remove a resource
2. POST		B. Retrieve a resource without changing it
3. PUT		C. Submit data to create a new resource
4. DELETE		D. Replace or update an existing resource

16 **Match each activity to the phase of a software engineering project where it mainly belongs.** **2 marks**

Item	Answer	Options
1. Writing the requirements and constraints		A. Identifying and defining
2. Creating a Gantt chart		B. Research and planning
3. Coding modules and reviewing each other's code		C. Producing and implementing
4. Acceptance testing with the client		D. Testing and evaluating
5. Choosing between Agile and Waterfall		
6. Comparing the finished product against the success criteria		

Section II

60 marks

Attempt ALL questions

Allow about 1 hour and 55 minutes for this section

Answer each question in the spaces provided. Write code in Python unless a question says pseudocode is acceptable.

17 Distinguish between symmetric and asymmetric encryption. **2 marks**

18 A login function is shown. **4 marks**

```
def login(username, password):
    query = ("SELECT * FROM users WHERE username = '" + username +
             "' AND password = '" + password + "'")
    return db.execute(query).fetchone()
```

(a) Explain how entering `admin' --` as the username could let an attacker log in without the password. **(2 marks)**

(b) Rewrite the function so it is secure. Assume each user's password is stored as a bcrypt hash in a column called `password_hash`. **(2 marks)**

19 A school is building an app that stores students' names, contact details and timetables. **3 marks**
Describe how the principles of *privacy by design* could be applied to this app.

20 A web app keeps users logged in using a session cookie. **4 marks**

(a) Outline how a session cookie keeps a user logged in between page requests. **(2 marks)**

(b) Describe TWO ways to make the session more secure. **(2 marks)**

21 This Flask route handles a form that adds a score to a leaderboard. **3 marks**

```
@app.route("/scores", methods=["POST"])
def add_score():
    name = request.form["name"]
    score = int(request.form["score"])
    db.execute("INSERT INTO scores (name, score) VALUES (?, ?)",
               (name, score))
    return redirect("/leaderboard")
```

(a) Outline what happens, from browser to database, when the form is submitted. **(2 marks)**

(b) Identify ONE validation check this route is missing. **(1 mark)**

22 A database has these tables: **3 marks**

```
Students(id, name, year)
Results(student_id, subject, mark)
```

Write an SQL query that lists the name and mark of every Year 12 student who scored 80 or more in Software Engineering, highest mark first.

23 Outline TWO ways that following the Web Content Accessibility Guidelines (WCAG) improves a website for its users. **2 marks**

24 Write a Python function `validate_password(pw)` that returns a list of the rules the password fails, in this order: **5 marks**

- `"length"` if it has fewer than 12 characters
- `"digit"` if it has no digit
- `"uppercase"` if it has no uppercase letter
- `"symbol"` if it has none of the characters `!@#$%^&*`

A password that passes every rule returns an empty list. For example, `validate_password("longpassword12")` returns `["uppercase", "symbol"]`.

25 Explain what *overfitting* is, and ONE way to prevent it. **2 marks**

26 A model predicts a student's test score $\hat{y}$ from the hours studied x using the regression line $\hat{y} = 6x + 40$. **4 marks**

(a) Predict the score of a student who studies for 7 hours. **(1 mark)**

(b) Explain why the model is unreliable for a student who studies for 20 hours. **(2 marks)**

(c) The model is tested on three students: (2 hours, 50), (5 hours, 72) and (8 hours, 86). Calculate the mean squared error. **(1 mark)**

27 Evaluate the impact of automation through machine learning on employment and on society. **6 marks**

28 A single neuron has inputs $x_1 = 2$ and $x_2 = 3$, weights $w_1 = 0.5$ and $w_2 = -1$, a bias of 1 and a ReLU activation function, where $\text{ReLU}(z) = \max(0, z)$. **4 marks**

(a) Calculate the neuron's output. Show your working. **(2 marks)**

(b) Outline how training would change this neuron if its output was too low. **(2 marks)**

29 A library system stores items. Every **LibraryItem** has a `title` and an `item_id`, and a method `describe()` that returns a string. A **Book** is a LibraryItem that also has an `author`. A **DVD** is a LibraryItem that also has a `runtime` in minutes. Book and DVD each override `describe()` to include their extra attribute. **5 marks**

Write Python code for all three classes.

30 With reference to your code in the previous question, explain how it shows *generalisation*, *inheritance* and *polymorphism*. Use the terms superclass and subclass. **3 marks**

31 A team is building a canteen ordering app using Scrum. **4 marks**

(a) Write a user story for ordering lunch, with TWO acceptance criteria. **(2 marks)**

(b) Explain how working in sprints helps the team manage changing requirements. **(2 marks)**

32 A school canteen app lets students log in, order food and pay online. Justify FOUR security measures the developers should build into the app, covering different parts of the system. **6 marks**

End of paper

Solutions and marking guidelines

Written for Trialbank. Not official NESA marking guidelines.

Section I

Q	Answer	Why
1	C	A parameterised query sends the value separately from the SQL, so input can't change the query. The other three build the SQL string from user input.
2	C	404 Not Found. 200 is OK, 301 is a permanent redirect, 500 is a server error.
3	B	PWAs are web apps that can be installed and use a service worker to cache content for offline use.
4	B	The model learnt the pattern in the historical decisions, which were themselves biased.
5	C	The balance is bound to the class and made private, and can only be changed through the deposit() method.
6	B	DAST tests the program while it runs. SAST and code review read the code without running it.
7	B	Only 8, 9 and 4 are greater than 3, and each is doubled.
8	B	The image is the bottleneck. Resizing it to the size it is displayed at cuts most of the download.
9	A, B, D	TLS gives encryption, server authentication and integrity checks. It does nothing for SQL injection, and DNS lookups still reveal the domain.
10	A, B, D, E, G	Circle never overrides area(), so it inherits Shape's version, which returns 0. Calling area() on objects of different classes through one loop is polymorphism.
11	A, C, E	Supervised learning needs labelled data. B is unsupervised (clustering) and D is reinforcement learning.
12	A, B, D, F	Output encoding, input sanitising and CSP stop injected scripts running. HttpOnly stops a script that does run from stealing the session cookie. Password hashing protects stored passwords, not against XSS.
13	1–C, 2–A, 3–B, 4–D (2 marks: all correct; 1 mark: at least half correct)	
14	1–C, 2–D, 3–E, 4–A, 5–B (2 marks: all correct; 1 mark: at least half correct)	
15	1–B, 2–C, 3–D, 4–A (2 marks: all correct; 1 mark: at least half correct)	
16	1–A, 2–B, 3–C, 4–D, 5–B, 6–D (2 marks: all correct; 1 mark: at least half correct)	

Section II

17 (2 marks)

Criteria	Marks
Clearly distinguishes between the two, with reference to keys	2
Describes one type	1

Sample answer

Symmetric encryption uses one shared secret key to both encrypt and decrypt, which is fast but means the key has to be shared securely. Asymmetric encryption uses a key pair: data encrypted with the public key can only be decrypted with the matching private key, so no secret has to be shared, but it is much slower. HTTPS uses asymmetric encryption to agree on a symmetric session key.

18 (4 marks)

Criteria	Marks
(a) Explains that the input closes the string and that -- comments out the password check, so the query matches the admin row	2
(a) Identifies SQL injection	1
(b) Uses a parameterised query AND checks the password against the stored hash	2
(b) Does one of these	1

Sample answer

(a) The query becomes `... WHERE username = 'admin' --' AND password = '...'`. The quote ends the username string, and `--` turns the rest of the line into a comment, so the password condition is never checked. The query returns the admin row and the attacker is logged in. This is SQL injection.

```
import bcrypt

def login(username, password):
    row = db.execute(
        "SELECT password_hash FROM users WHERE username = ?",
        (username,)).fetchone()
    return row is not None and bcrypt.checkpw(password.encode(), row[0])
```

19 (3 marks)

Criteria	Marks
Describes several privacy by design principles, each applied to the app	3
Outlines some principles with some link to the app	2
Identifies a relevant principle	1

Sample answer

Privacy is built in from the start rather than added after a breach. The app should collect only the data it needs (data minimisation): for example, no home address if timetables don't need it. Privacy should be the default, so contact details are hidden from other students unless a student chooses to share them. Data should be protected end to end: encrypted in transit with HTTPS and at rest in the database, with access limited by role. The school should be transparent through a clear privacy policy, and data should be deleted when a student leaves.

20 (4 marks)

Criteria	Marks
(a) Outlines that the server creates a session ID after login, the browser stores it in a cookie and sends it with each request, and the server looks it up	2
(a) Identifies a feature	1
(b) Describes two appropriate measures	2
(b) Describes one	1

Sample answer

(a) After a successful login the server creates a random session ID, stores it with the user's details, and sends it to the browser in a cookie. HTTP is stateless, so the browser sends the cookie with every later request, and the server looks up the ID to know who the user is.

(b) Any two: set the **Secure** flag so the cookie is only sent over HTTPS; set **HttpOnly** so JavaScript (and so an XSS attack) can't read it; set **SameSite** to reduce CSRF; make sessions **expire** after inactivity and on logout; **regenerate** the session ID after login to prevent session fixation.

21 (3 marks)

Criteria	Marks
(a) Outlines the POST request, the back-end reading the form data and inserting it, and the redirect	2
(a) Some relevant steps	1
(b) Identifies a missing check	1

Sample answer

(a) The browser sends an HTTP POST request to /scores with the form fields. On the back end, Flask runs add_score(), reads name and score from the request, converts the score to an integer and inserts a row with a parameterised query. The server then returns a redirect, and the browser requests /leaderboard.

(b) Any one: a non-numeric score crashes `int()` (no try/except); no range check on the score (for example 0 to 100); no check that the name is present or under a maximum length.

22 (3 marks)

Criteria	Marks
Correct query with join, all three conditions and correct ordering	3
Query with one error	2
Some correct SQL	1

Sample answer

```
SELECT Students.name, Results.mark
FROM Students
JOIN Results ON Students.id = Results.student_id
WHERE Students.year = 12
  AND Results.subject = 'Software Engineering'
  AND Results.mark >= 80
ORDER BY Results.mark DESC;
```

23 (2 marks)

Criteria	Marks
Outlines two ways	2
Outlines one way	1

Sample answer

Any two: alt text on images lets screen readers describe them to vision-impaired users; sufficient colour contrast makes text readable for people with low vision or colour blindness; full keyboard navigation helps people who can't use a mouse; captions help deaf or hard-of-hearing users; clear headings and labels make the page easier for everyone to follow.

24 (5 marks)

Criteria	Marks
Correct function that passes all tests, including an empty list for a valid password	5
Correct function with one minor error	4
Checks most rules correctly	3
Checks some rules correctly	2
Some relevant code	1

Sample answer

```
def validate_password(pw):
    failed = []
    if len(pw) < 12:
        failed.append("length")
```

```
    if not any(c.isdigit() for c in pw):
        failed.append("digit")
    if not any(c.isupper() for c in pw):
        failed.append("uppercase")
    if not any(c in "!@#$%^&*" for c in pw):
        failed.append("symbol")
    return failed
```

Tests: "Short1!" gives ["length"]; "longpassword12" gives ["uppercase", "symbol"]; "Correct#Horse9Battery" gives [].

25 (2 marks)

Criteria	Marks
Explains overfitting and a valid way to prevent it	2
Outlines overfitting or a prevention method	1

Sample answer

Overfitting is when a model learns the training data too closely, including its noise, so it scores well on training data but poorly on new data. It can be prevented by testing on a separate validation set and stopping training when validation error starts rising (early stopping), or by using more training data or a simpler model.

26 (4 marks)

Criteria	Marks
(a) 82	1
(b) Explains that 20 hours is outside the range of the training data (extrapolation) and the prediction of 160 exceeds the maximum possible score	2
(b) Identifies one reason	1
(c) MSE = 4	1

Sample answer

(a) 6 × 7 + 40 = 82

(b) The model predicts 6 × 20 + 40 = 160, which is impossible on a test out of 100. Twenty hours is outside the range of the data the model was trained on, so this is extrapolation: the straight-line relationship probably doesn't hold (returns diminish as scores approach the maximum).

(c) Predictions are 52, 70 and 88. Errors are −2, 2 and −2, so squared errors are 4, 4 and 4. MSE = (4 + 4 + 4) ÷ 3 = 4.

27 (6 marks)

Criteria	Marks

Makes a well-supported judgement, with detailed positive and negative effects on both employment and society and relevant examples	5–6
Describes positive and negative effects on employment and society	3–4
Outlines some effects	1–2

Sample answer

Employment: ML automates repetitive, rules-based tasks such as data entry, invoice processing and basic customer service, which reduces those jobs and puts most pressure on low-skilled workers. At the same time it creates new roles (data scientists, ML engineers, people who maintain and audit models) and frees workers from dangerous or tedious work. The net effect depends on reskilling: workers whose jobs change need training to move into the new roles.

Society: automation lowers costs and enables new services, such as faster medical image screening and fraud detection. However, models trained on biased data can make unfair decisions in hiring, lending or policing at a large scale, and "black box" models make those decisions hard to explain or challenge. Large datasets also raise privacy concerns, and the benefits can flow mainly to the companies that own the technology, widening inequality.

Judgement: overall the impact is positive for productivity and safety, but only if it is managed: governments and businesses need to invest in reskilling and require transparency and bias testing in high-stakes decisions.

28 (4 marks)

Criteria	Marks
(a) Correct weighted sum (−1) and output (0)	2
(a) Correct weighted sum or a correct method	1
(b) Outlines that the error is backpropagated and the weights and bias are adjusted (gradient descent) to reduce the error	2
(b) States the weights change	1

Sample answer

(a) $z = (0.5 \times 2) + (-1 \times 3) + 1 = 1 - 3 + 1 = -1$. Output = ReLU(−1) = max(0, −1) = 0.

(b) A loss function measures how far the output is from the target. Backpropagation calculates how much each weight and the bias contributed to that error, and gradient descent adjusts them by a small amount (set by the learning rate), for example increasing w_2 or the bias so z becomes positive. This repeats over many examples until the error is low.

29 (5 marks)

Criteria	Marks

All three classes correct: subclasses extend LibraryItem, call super().__init__, add their attribute and override describe()	5
Mostly correct with one error (for example a missing super().__init__)	4
Superclass and at least one subclass mostly correct	3
Superclass correct or partial subclasses	2
Some relevant code	1

Sample answer

```
class LibraryItem:
    def __init__(self, title, item_id):
        self.title = title
        self.item_id = item_id

    def describe(self):
        return f"{self.item_id}: {self.title}"


class Book(LibraryItem):
    def __init__(self, title, item_id, author):
        super().__init__(title, item_id)
        self.author = author

    def describe(self):
        return f"{super().describe()} by {self.author}"


class DVD(LibraryItem):
    def __init__(self, title, item_id, runtime):
        super().__init__(title, item_id)
        self.runtime = runtime

    def describe(self):
        return f"{super().describe()} ({self.runtime} min)"
```

30 (3 marks)

Criteria	Marks
Explains all three concepts with correct terms and specific reference to the code	3
Explains two, or all three with limited reference to the code	2
Outlines one concept	1

Sample answer

Generalisation: the attributes and behaviour common to every item (title, item_id, describe()) are moved up into the superclass LibraryItem instead of being repeated. **Inheritance:** Book and DVD are subclasses that inherit title, item_id and describe() from LibraryItem, and call super().__init__() so the superclass sets them up. **Polymorphism:** each subclass overrides describe(), so calling item.describe()

on a list of mixed Books and DVDs runs the right version for each object without the caller checking its type.

31 (4 marks)

Criteria	Marks
(a) User story in the correct form with two testable acceptance criteria	2
(a) User story or criteria	1
(b) Explains how short iterations with feedback and a reprioritised backlog absorb change	2
(b) Outlines a feature of sprints	1

Sample answer

(a) As a student, I want to order and pay for my lunch before recess so that I don't have to queue. Acceptance criteria: orders close at 10:30 am on the day; the student receives an order number and an order summary on screen after paying.

(b) Each sprint is a short, fixed period (usually 1 to 4 weeks) that ends with working software shown to the client in a sprint review. Feedback and new requirements are added to the product backlog and reprioritised before the next sprint starts, so changes are absorbed every few weeks instead of forcing a redesign of a plan fixed at the start.

32 (6 marks)

Criteria	Marks
Justifies four appropriate measures across different parts of the system, each linked to a specific threat	5–6
Describes three or four measures with some justification	3–4
Outlines some measures	1–2

Sample answer

Authentication: store passwords as salted hashes (bcrypt) and offer multi-factor authentication, so a stolen database doesn't reveal passwords and a guessed password alone can't take over an account. **Input handling:** validate all input on the server and use parameterised queries and output encoding, which stops SQL injection and XSS through order notes or names. **Network:** serve everything over HTTPS with Secure, HttpOnly and SameSite cookies, so payment and login data can't be read or changed in transit and sessions can't be stolen. **Payments and data:** use a certified payment provider instead of storing card details, and give the database account least privilege. **Testing and monitoring:** run SAST and DAST before release and log logins and orders, so vulnerabilities are found early and suspicious activity can be traced (accountability).